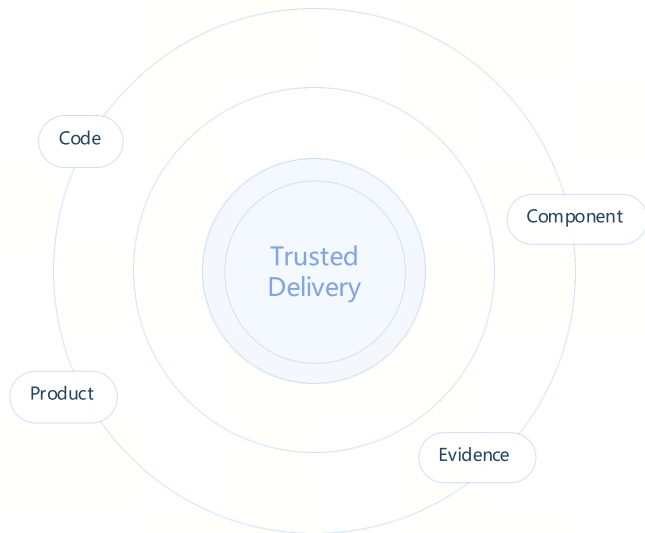


CRA • DIGITAL PRODUCT RESPONSIBILITY

从 Code 到 Component

CRA 驱动的软件风险一体化治理

白懿轩



为什么叫“从 Code 到 Component”？

不是把代码扫描扩展到组件扫描，而是软件生产从内部编写走向持续组装。

CODE · 企业内部创造

产品如何执行

自研代码、业务逻辑、函数调用、数据流、执行路径、AI生成代码与代码缺陷，决定产品在真实场景中如何运行

输入传播

调用路径

触发条件

修复验证

COMPONENT · 外部能力进入产品

产品由什么构成

开源组件、商业SDK、基础镜像、框架、中间件、云服务和模型能力，持续进入构建制品与产品版本。

PURL / SBOM

直接/传递依赖

二进制

版本范围

98%

受审计代码库包含开源组件

1,180

平均每个应用包含的开源组件

64%

开源组件为传递依赖

16%

需要深度方法识别清单外内容

企业不只要知道“写了什么”，更要持续知道“最终交付了什么、进入了哪些版本”。

CRA把事件响应压缩到小时级

早期预警

24h

先形成第一份产品影响判断：事件类型、已知事实、初步影响范围和后续补充路径。

主要通知

72h

补充技术分析、影响情况、已采取措施、漏洞状态和修复或缓解进展。

完整报告

Final

沉淀原因、影响、缓解措施、修复结果、复验结论和责任证据。

真正的压力，不是24小时内完成所有调查，而是24小时内能够形成第一份可信的产品判断。

外部信号

CVE / GHSA、上游公告、厂商通告、Issue 与 PR 同时涌入。

企业事实

组件身份、代码路径、构建制品和产品版本往往分散在不同系统。

行动输出

监管沟通、修复安排和内部协同，都依赖同一份产品影响判断。

从风险信号到产品影响判断

情报、组件、代码与制品事实，需要在同一产品版本语境中完成关联研判。

01 统一风险输入

CVE / GHSA、GitHub Issue、Security PR、上游公告、厂商通告、私有漏洞库

02 确认风险进入了什么

组件身份归一、PURL / CPE映射、SBOM资产命中、镜像 / 二进制识别、构建制品与产品版本反溯。

03 确认风险是否真实成立

外部输入、污点传播、调用路径、跨函数跨文件分析、触发条件、可达性。

04 形成可执行产品判断

受影响产品与版本、组件与代码研判依据、修复 / 升级 / 缓解建议、发布门禁或持续监测策略。

SECTREN 产品数据情报与制品溯源系统

系统版本: 2023-04-01-01

发布周期: 2023-03-15 更新时间: 2023-04-24

CSA: 2023-03-24

CSA: 2023-03-24

CSA: 2023-03-24

CSA: 2023-03-24

CSA: 2023-03-24

CSA: 2023-03-24

CSA: 2023-03-24

CSA: 2023-03-24

CSA: 2023-03-24

CSA: 2023-03-24

CSA: 2023-03-24

CSA: 2023-03-24

CSA: 2023-03-24

CSA: 2023-03-24

CSA: 2023-03-24

CSA: 2023-03-24

CSA: 2023-03-24

CSA: 2023-03-24

CSA: 2023-03-24

CSA: 2023-03-24

CSA: 2023-03-24

CSA: 2023-03-24

CSA: 2023-03-24

CSA: 2023-03-24

CSA: 2023-03-24

CSA: 2023-03-24

CSA: 2023-03-24

CSA: 2023-03-24

CSA: 2023-03-24

CSA: 2023-03-24

CSA: 2023-03-24

CSA: 2023-03-24

CSA: 2023-03-24

CSA: 2023-03-24

CSA: 2023-03-24

CSA: 2023-03-24

CSA: 2023-03-24

CSA: 2023-03-24

CSA: 2023-03-24

CSA: 2023-03-24

CSA: 2023-03-24

CSA: 2023-03-24

CSA: 2023-03-24

CSA: 2023-03-24

CSA: 2023-03-24

CSA: 2023-03-24

CSA: 2023-03-24

CSA: 2023-03-24

jsoup 跨站脚本漏洞

CVE-2022-36033 CVEID: 202208-4329 ELVD: 2022-0828 发布日期: 2022-08-30 01:15 更新时间: 2022-12-08 11:48

文件路径

...jsoup_reachable_sink.java

所在行

本地文件

9

1

2

3

4

5

6

7

8

9

10

11

12

13

14

15

16

17

18

19

20

21

22

23

24

25

26

27

28

29

30

31

32

33

jsoup 跨站脚本漏洞

CVE-2022-36033 CVEID: 202208-4329 ELVD: 2022-0828 发布日期: 2022-08-30 01:15 更新时间: 2022-12-08 11:48

文件路径

...jsoup_reachable_sink.java

所在行

本地文件

9

1

2

3

4

5

6

7

8

9

10

11

12

13

14

15

16

17

18

19

20

21

22

23

24

25

26

27

28

29

30

31

32

33

技术分析的价值，不在于生成更多风险记录，而在于明确风险究竟进入了哪些产品，以及下一步应该采取什么行动。

CRA把责任从发布前延伸到整个产品周期

01	02	03	04	05
设计开发 代码缺陷、组件选择、AI生成代码和第三方能力引入。	构建发布 SBOM、构建制品、镜像、二进制和版本基线。	产品交付 正式产品版本、支持分支、交付内容与变更记录。	上市后运行 新增漏洞、EOL变化、VEX状态与风险复评。	支持期结束 责任退出条件、风险接受和证据归档。

责任周期从“发布前检查”延伸为“支持期内持续判断”。

同一个产品版本在发布时可能没有风险，但上游组件、漏洞情报、生命周期状态和代码变更会在后续持续改变风险状态。

CRA改变的不只是一次发布检查，而是整个产品支持周期中的持续责任。

产品软件资产：从静态清单到持续基线

软件构成、版本关系、生命周期状态与风险信息，需要随每一次构建和发布持续演化。

01 风险与供应链输入

公共漏洞情报、早期情报、私有漏洞库、厂商公告、上游Issue与PR。

02 软件构成识别

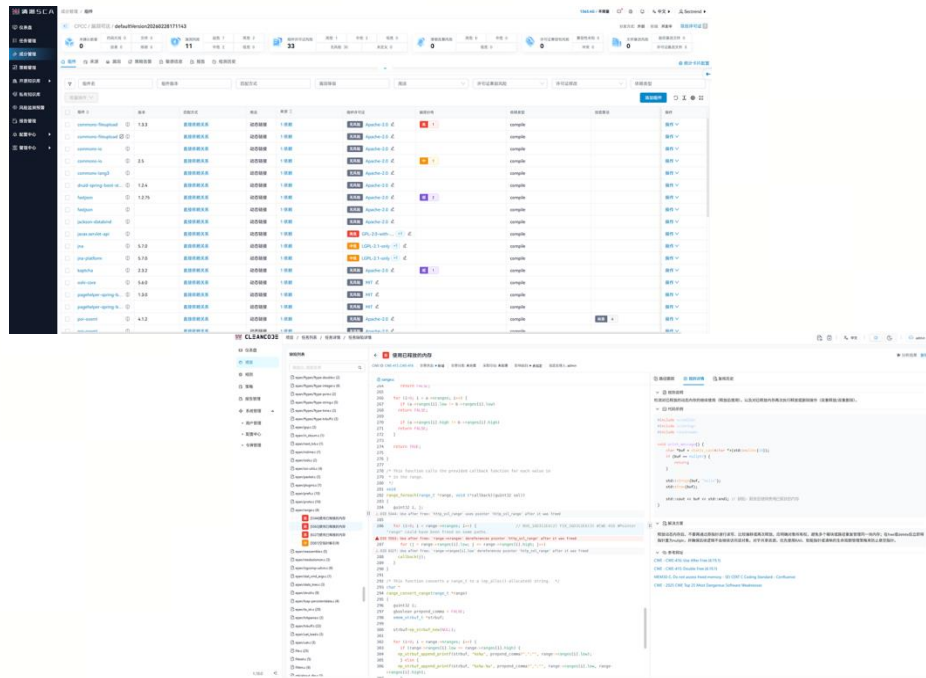
自研代码、开源组件、商业SDK、基础镜像、二进制制品、直接与传递依赖。

03 产品版本基线

构建制品、正式产品版本、支持分支、历史交付版本、产品版本与SBOM绑定。

04 持续状态演化

组件版本、漏洞、EOL、VEX、许可证、修复与复验状态随情报和发布持续更新。



企业真正需要持续掌握的，不是一份组件清单，而是每一个产品版本当前的软件构成与风险状态。

CRA改变了责任证明方式

不只是证明做过检测，而是证明判断、决策和处置过程。



只有能够解释为什么这样判断、为什么这样处置，扫描结果才真正成为责任证据。

让每一次判断和处置都可以追溯、复验

情报、SCA、SAST、VEX、EOL、SBOM和处置记录在同一条证据链中连续留痕。

证据连续留痕

风险进入

公共情报、私有漏洞库、厂商通告

技术研判

SCA命中、SAST路径、VEX/EOL状态

产品决定

修复、缓解、接受、门禁或监测

任务执行

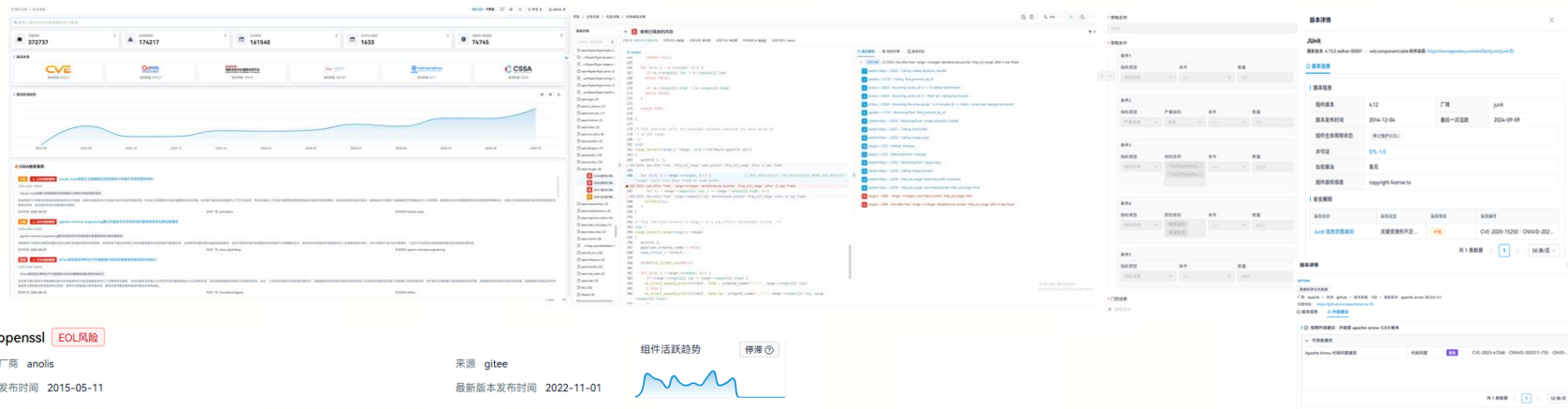
负责人、计划、补丁、升级建议

修复复验

代码复验、制品复扫、版本验证

持续复评

情报更新、状态失效、证据归档



证据链不是额外制作的一份报告，而是在风险处理过程中持续产生的记录。

从软件安全，走向数字产品韧性

CRA要求企业具备的，不只是检测能力，而是在软件供应链持续变化时保持产品可交付、风险可控制、责任可证明的能力。

软件风险治理的终点，
不是发现更多漏洞，
而是让企业在软件供应链变化中
持续保持产品控制力。

当产品由自研代码、开源组件、商业SDK、基础镜像、云服务和AI能力持续
组装，安全能力必须从“发现问题”上升为“保障数字产品持续可信”。

Code与Component的统一，不是工具整合，而是企业对数字产品的持续控制力。

INNOVATIO

创新韧性

在开放创新与风险控制之间保持平衡。

SUPPLY CHAIN

供应链韧性

在上游变化中保持产品连续性。

数字产品 韧性

MARKET

市场韧性

安全与合规从内部管理要求，转化为市场准入与供应链协作的基础条件。

ACCOUNTABILITY

责任韧性

让责任证明成为持续过程，而不是临时补材料。

可信交付，成为软件供应链时代的新竞争力

软件企业的竞争力，正在从开发效率延伸到风险控制、责任证明和市场信任。

企业未来需要证明的，
不只是软件能够运行，
而是软件值得被持续信任。

软件企业的竞争力，正在从开发效率延伸到风险控制、责任证明和市场信任。速度之外，透明、可控和可证明正在成为可信交付的基础。

Build Fast.

Control Risk.

Prove Trust.

软件生产已经供应链化

企业交付的产品由自研代码、开源组件、商业SDK、基础镜像、云服务和AI能力共同构成。

软件责任正在持续化

产品发布不是责任结束，而是持续监测、持续判断、持续处置和持续证明的开始。

软件竞争正在走向可信交付

未来市场不仅关注产品是否可用，也关注产品构成是否透明、风险是否可控、责任是否可证明。

THANK YOU

上海安势信息技术有限公司